

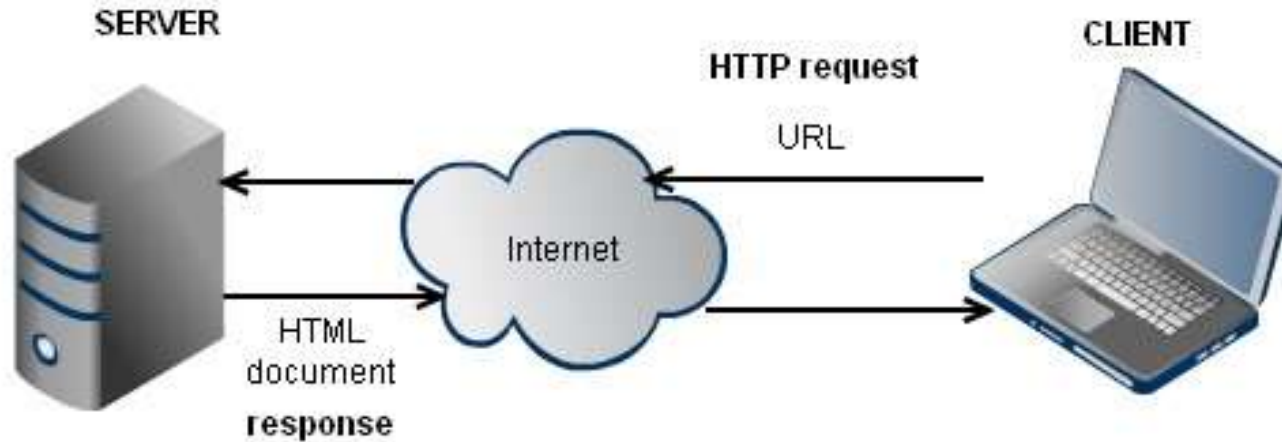


11. Hafta

WEB GÜVENLİĞİ SALDIRI VE SAVUNMA YÖNTEM-ARAÇLARI (TEMİZ KOD)

Web

- TCP/IP
 - Http protokolü
 - Web Server



HTTP Metodları

Yöntem	Açıklama
GET	Sunucudan bir kaynağı ister
HEAD	GET gibi kullanılır ama sadece Header getirir ve içerik getirmez
POST	Sunucuda bulunan verinin içeriğini değiştirmesini ister
PUT	Sunucuda bir kaynak yaratmasını veya başka kaynak ile değiştirmesini ister
DELETE	Sunucuda bulunan bir kaynağı silmesini ister
CONNECT	SSL bağlantıların HTTP bağlantıları içinden geçmesini sağlar
OPTIONS	Sunucudan bir kaynakla ilgili geçerli yöntemleri ister
TRACE	Sunucunun istek Header'larını geri göndermesini ister

HTTP Durum Kodları

404

Page not found

- **1xx:** Bilgi mesajları.
- **2xx:** Başarılı istek yanıtları.
- **3xx:** İstemciyi başka bir kaynağa yönlendiren yanıtlar.
- **4xx:** Bir hata barındıran isteklere karşı üretilen yanıtlar.
- **5xx:** Sunucu tarafında istek karşılanmaya çalışılırken bir hata alındığına ilişkin yanıtlar.

Http Header Bilgileri

- Request
 - Cf-Connecting-Ip
 - Cookie
 - Accept-Language
 - Referer
 - Accept
 - User-Agent
 - Upgrade-Insecure-Requests
 - Cf-Visitor
 - X-Forwarded-Proto
 - Cf-Ray
 - X-Forwarded-For
 - Cf-Ipcountry
 - Accept-Encoding
 - Connection
 - Host
- Response
 - Content-Base
 - Content-Length
 - Cache-Control
 - Content-Type
 - Date
 - eTag
 - Last-Modified
 - Location
 - Server
 - Set-Cookie
 - X-Powered-By
 - WWW-Authenticate
 - Connection

Bir web sitesinin header bilgilerini görmek için; <https://headers.cloxy.net/> adresinden yararlanılabilir.

HTTP Status for: "http://www.siberguvenlik.xyz/ders"

View HTTP Response Header

- **HTTP/1.1 301 Moved Permanently**
- Content-Type: text/html; charset=UTF-8
- Location: http://www.siberguvenlik.xyz/ders/
- Server: Microsoft-IIS/8.5
- X-Powered-By: ASP.NET
- X-Powered-By-Plesk: PleskWin
- Date: Wed, 11 Apr 2018 08:23:37 GMT
- Connection: close
- Content-Length: 157
- **HTTP/1.1 200 OK**
- Cache-Control: private
- Content-Type: text/html
- Server: Microsoft-IIS/8.5
- Set-Cookie: ASPSESSIONIDQSTSDDDR=GHKFADOCEGNLEOFEALGKFDLE; path=/
- X-Powered-By: ASP.NET
- X-Powered-By-Plesk: PleskWin
- Date: Wed, 11 Apr 2018 08:23:38 GMT
- Connection: close
- Content-Length: 38959

Your Request HTTP Headers

- Cf-Connecting-Ip: 193.140.54.45
- Cookie: __cfduid=de3ab415b76cb4c44d52cbff5ad93e0961523004145; cf_clearance=9d90a79bb03eb97bba1977a1414da58da13a1a00-1523435030-90
- Accept-Language: tr-TR,tr;q=0.9,en-US;q=0.8,en;q=0.7
- Referer: https://headers.cloxy.net/request.php
- Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
- User-Agent: Mozilla/5.0 (Windows NT 10.0) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/65.0.3325.181 Safari/537.36
- Upgrade-Insecure-Requests: 1
- Cf-Visitor: {"scheme":"https"}
- X-Forwarded-Proto: https
- Cf-Ray: 409c0daf8c572926-OTP
- X-Forwarded-For: 193.140.54.45
- Cf-Ipcountry: TR
- Accept-Encoding: gzip
- Connection: close
- Host: headers.cloxy.net

Sunucu Teknolojileri

- Scripting dilleri (PHP, VBScript, Perl)
- Web uygulama platformları (ASP.NET, Java)
- Web sunucuları (Apache, IIS, nginx)
- Veritabanları (MS-SQL, Oracle, MySQL)
- ve diğer destekleyici servislerdir (File Systems, SOAP tabanlı web servisleri, izin servisleri)
- İstemci gönderileri
 - URL sorgu string'leri
 - HTTP cookie'leri
 - POST metodu ile yapılan istek mesaj gövdeleri

Web Lab Uygulama Yazılımları

- **DVWA**
- Mutillidae
- SQLol
- Hackxor
- The Bodgelt Store
- Exploit KB / exploit.co.il Vulnerable Web App
- WackoPicko
- WebGoat
- OWASP Hackademic Challenges Project
- XSSeducation

Damn Vulnerable Web App (DVWA)

- Web uygulama güvenliği alanında kendini geliştirmek isteyenler için PHP ile oluşturulmuş içinde belli web zafiyetlerini barındıran bir eğitim sistemidir.
- Barındırdığı Zafiyetler:
 - Brute Force
 - Command Execution
 - CSRF
 - File Inclusion
 - SQL Injection
 - Upload
 - XSS Reflected
 - XSS Stored



DVWS Uygulamaları

- Sanal makine Metasploitable2
- Firefox tarayıcısı

metasploitable2

Warning: Never expose this VM to an untrusted network!

Contact: `msfdev[at]metasploit.com`

Login with `msfadmin/msfadmin` to get started

- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)

